HƯỚNG DẪN KIỂM TRA & NGHIỆM THU ĐỒ ÁN BTL

HỌC PHẦN: KỸ THUẬT LẬP TRÌNH AN TOÀN (CSE703093 / CSE703153)

Giảng viên hướng dẫn: ThS. Vũ Quang Dũng — Đại học Phenikaa

Nhóm 11: Chủ đề 4 — Dự án Fuzzing (FZP1 Binary Parser)

---

1. TỔNG QUAN DỰ ÁN

- Đề tài: Phân tích Cú pháp Gói tin Nhị phân FZP1 & Đo lường Đối sánh 3 Trường phái Fuzzing (Black-box vs Greybox vs White-box Concolic SMT Z3).
- Thành viên nhóm: Lưu Đức Hiệp (50%) & Hà Nguyễn Trúc Linh (50%) — [Mã sinh viên và Lớp bảo mật theo quy định].
- Cấu trúc gói nộp:
- `specification/Nhom11_FZP1_Fuzzing_Spec.xlsx`: Tệp đặc tả 10 sheet chuẩn SSOT theo yêu cầu môn học.
- `source/`: Mã nguồn C bản lỗi (`fzp1_parser_v0.c`) và bản vá CERT C (`fzp1_parser_v1.c`).
- `report/BaoCao_BTL_Nhom11.pdf`: Báo cáo chính thức 8 phần chuẩn mực theo `report_guide.pdf`.
- `results/`: Dữ liệu thô JSON của 30 lượt chạy benchmark, biểu đồ và nhật ký kiểm định.

---

2. CÁC LỆNH KIỂM TRA VÀ TÁI LẬP KẾT QUẢ (REPRODUCIBILITY)

Bước 1: Biên dịch mã nguồn C

```
# Biên dịch cả 2 phiên bản bằng GCC (MinGW-w64 UCRT64)
gcc -Wall -Wextra -O0 -g -fstack-protector-all source/fzp1_parser_v0.c -o source/fzp1_parser_v0.exe
gcc -Wall -Wextra -O0 -g -fstack-protector-all source/fzp1_parser_v1.c -o source/fzp1_parser_v1.exe
```

Bước 2: Chạy kiểm thử tự động toàn diện (Pytest)

```
pytest tests/test_fzp1_parser.py -v
# Kết quả mong đợi: 10 passed trong < 1.0 giây
```

Bước 3: Kiểm chứng lỗi và bản vá bằng tệp tấn công

```
# 1. Chạy bản lỗi v0 với gói tin payload > 16 byte -> Quan sát hiện tượng SẬP (Crash / Access
Violation)
.\source\fzp1_parser_v0.exe crashes\whitebox_s0_crash_0.bin
# Mã lỗi trả về: 3221225501 (STATUS_ACCESS_VIOLATION do ghi đè stack canary)

# 2. Chạy bản vá v1 với cùng tệp tấn công -> Quan sát cơ chế TỪ CHỐI AN TOÀN (CERT STR31-C)
.\source\fzp1_parser_v1.exe crashes\whitebox_s0_crash_0.bin
# Thông báo: [SECURITY_REJECT] Payload length 26 exceeds maximum allowed buffer 16
# Mã lỗi trả về: 2 (Từ chối an toàn, không có lỗi sập bộ nhớ)
```

Bước 4: Chạy lại Benchmark 30 lượt thử nghiệm

```
python scripts/run_fzp1_benchmark.py
python scripts/aggregate_results.py
python scripts/generate_charts.py
# Dữ liệu được cập nhật tại results/data_raw/ và biểu đồ tại results/figures/
```

Bước 5: Chạy công cụ thẩm định tính toàn vẹn dự án

```
python scripts/verify_project.py
# Kết quả mong đợi: 10/10 TIÊU CHÍ ĐẠT CHUẨN (PASS)
```

---

3. TÓM TẮT KẾT QUẢ ĐẠT ĐƯỢC

- Tỷ lệ tìm thấy lỗi qua 30 trials:
- Black-box (Ngẫu nhiên mù quáng): 0% (0/30) — Rào cản toán học $P = 1/2^{40} \approx 9.09 \times 10^{-13}$.
- Greybox (Biết Magic header): 80% (24/30) — Trung vị 2.58 giây.
- White-box (Z3 SMT Solver): 100% (30/30) — Thời gian giải trung bình 7.16 ms, tìm ra crash ngay trong vòng lặp đầu tiên.
- Chuẩn hóa bản vá: Tuân thủ 100% CERT STR31-C, CERT MEM31-C, CERT MEM30-C.